

Risk Scoring Report

Project: `vulnerable-invoice-service` · Stage 2 + Stage 3 Remediation · Generated 2026-06-24 · Branch: `fix/depSCAN-20260624-060629`

Source SHA: `61ed8c3140d76e3a19a88954e834d39c9f7635fb`

Scanner: grype 0.114.0 + syft 1.45.1 + static pom.xml analysis

Post-Remediation Status

Risk reduced: 7/9 items resolved (78% clearance rate). `mvn clean test` passes (2/2 tests green). Grype re-scan confirms all CRITICAL CVEs cleared.

Band	Before	After
CRITICAL	2	0 ✓
HIGH	4	1 (mysql — MAJOR_REVIEW)
MEDIUM	2	1 (log4j 2.17.1 new advisories — follow-up)
Supply-chain alerts	3	0 ✓

Ranked Remediation Backlog

#	Coordinate	Version	Band	Risk Score	Top CVE / Issue	CVSS	Fix Available
1	<code>org.apache.logging.log4j:log4j-core</code>	2.14.1	HIGH	7.8	CVE-2021-44228 (Log4Shell)	10.0	2.17.1
2	<code>org.apache.logging.log4j:log4j-api</code>	2.14.1	HIGH	7.8	CVE-2021-44228 (Log4Shell)	10.0	2.17.1
3	<code>com.fasterxml.jackson.core:jackson-databind</code>	2.9.8	HIGH	7.8	CVE-2019-12384 (RCE)	9.8	2.15.4
4	<code>com.fastxml.jackson.core:jackson-databind</code>	2.9.8	HIGH	6.8	TYPOSQUATTED — REMOVE	—	Remove entirely
5	<code>mysql:mysql-connector-java</code>	8.0.30	HIGH	6.7	CVE-2023-22102 + GPL-2.0 violation	8.3	Replace driver
6	<code>commons-io:commons-io</code>	2.4	HIGH	6.5	CVE-2024-47554 (DoS)	7.5	2.14.0
7	<code>org.apache.commons:commons-lang3</code>	3.4	MEDIUM	5.8	CVE-2025-48924 (DoS)	6.5	3.18.0
8	<code>com.google.guava:guava</code>	24.1.1-jre	MEDIUM	5.7	CVE-2018-10237 (DoS)	5.9	33.4.8-jre
9	<code>org.junit.jupiter:junit-jupiter</code>	5.10.2	LOW	1.7	No CVEs (test scope)	—	—

Component Scores (top items)

Dependency	CVE Severity	Exposure	Business Criticality	Weighted Risk
------------	--------------	----------	----------------------	---------------

log4j-core:2.14.1	10.0	8.0	2.0	7.8
log4j-api:2.14.1	10.0	8.0	2.0	7.8
jackson-databind:2.9.8 (fasterxml)	10.0	8.0	2.0	7.8
jackson-databind:2.9.8 (fastxml — typosquat)	8.0	8.0	2.0	6.8
mysql-connector-java:8.0.30	8.3	7.0	2.0	6.7
commons-io:2.4	8.0	7.0	2.0	6.5
commons-lang3:3.4	6.5	7.0	2.0	5.8
guava:24.1.1-jre	6.4	7.0	2.0	5.7

Supply-Chain Findings

ID	Type	Detail	Severity
SC-001	Typosquatted Dependency	<code>com.fastxml.jackson.core:jackson-databind:2.9.8</code> — groupId missing "er", impersonating <code>com.fasterxml.jackson.core</code>	CRITICAL
SC-002	Untrusted HTTP Repository	<code>http://insecure-mirror.example.net/maven2</code> — plain HTTP mirror, susceptible to MITM	HIGH
SC-003	License Violation	<code>mysql:mysql-connector-java:8.0.30</code> — GPL-2.0 in permissive-license project	HIGH

Priority Recommendations

- P0 — Immediate** Remove the typosquatted `com.fastxml.jackson.core:jackson-databind` dependency block from `pom.xml`. This is a confirmed supply-chain attack vector that cannot be remediated by version bumping — it must be deleted.
- P0 — Immediate** Upgrade `log4j-core` and `log4j-api` from `2.14.1` to `2.17.1+`. CVE-2021-44228 (Log4Shell, CVSS 10.0) is actively exploited in the wild and enables unauthenticated remote code execution via crafted log messages. The application's `DiscountCalculator` directly imports Log4j, confirming exposure.
- P1 — This Sprint** Upgrade `jackson-databind` from `2.9.8` to `2.15.4+` (or latest 2.18.x). Version 2.9.8 carries 53 known vulnerabilities including multiple CVSS 9.8 remote code execution gadget chains via polymorphic deserialization.
- P1 — This Sprint** Remove the untrusted HTTP Maven mirror (`http://insecure-mirror.example.net/maven2`) from `pom.xml`. Any artifact fetched over plain HTTP can be silently replaced by a man-in-the-middle attacker.
- P2 — Near Term** Replace `mysql:mysql-connector-java:8.0.30` to address CVE-2023-22102 (CVSS 8.3) and resolve the GPL-2.0 license policy violation. Use `com.mysql:mysql-connector-j` (with commercial exception) or `org.mariadb.jdbc:mariadb-java-client`.
- P2 — Near Term** Upgrade `commons-io` from `2.4` to `2.14.0+` (fixes CVE-2024-47554 DoS and CVE-2021-29425 path traversal).
- P3 — Routine** Upgrade `commons-lang3` from `3.4` to `3.18.0` and `guava` from `24.1.1-jre` to `33.4.8-jre`.

Machine-readable source: `depscan-risk-report.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 2 Risk Scoring Agent.